Final Project

Disaster Recovery and Business Continuity Plan for Healthcare IT Systems

Sai Naga Sabarish Yerramsetty
Department of Cybersecurity of Information Assurance
University of Central Missouri
CYBER 5050: Disaster Recovery and Business Continuity
Dr. Richard Morphy
April 28, 2025

Table of Contents

1. Risk Assessment
2. Business Impact Analysis (BIA)
3. Emergency Response Plan
4. Communication Plan
5. Recovery Strategies
6. IT Infrastructure Inventory
7. IT and Data Backup Plan
8. Data Backup and Restoration Plan
9. Resource Inventory
10. Training and Awareness Programs
11. Testing and Maintenance
12. Appendices

- Appendix A: Updated Network Diagram
- Appendix B: MTD, RTO, RPO Table
- Appendix C: Incident Response Plan
- Appendix D: Restoration Procedures

13. References

1. Risk Assessment

System	Threat	Risk Impact	Score
EHR System	T1078: Valid Accounts	Unauthorized access, HIPAA violations	High
PACS	T1496: Resource Hijacking	Data corruption, unauthorized access	High
CPOE	T1565.001: Data Manipulation	Incorrect medical orders	Critical
LIMS	T1046: Network Service Discovery	Compliance violations	High
Telemedicine	T1056.001: Keylogging	Data exposure, identity theft	High

2. Business Impact Analysis (BIA)

System	Operational Impact	Financial Impact	Recovery Priority
EHR System	Delays in treatment, loss of patient trust	HIPAA fines, legal actions	High
PACS	Imaging data unavailability	Rescheduling costs	Medium
CPOE	Incorrect prescriptions	Liability claims	Critical
LIMS	Delayed lab reports	Regulatory fines	High
Telemedicine	Service downtime	Revenue loss	Medium

3. Emergency Response Plan

- **EHR Breach**: Immediate credential reset and activation of incident response procedures.
- **PACS Exploitation**: Isolate compromised servers and notify the cybersecurity team.
- **CPOE Manipulation**: Validate recent physician orders and rollback incorrect entries.
- **LIMS Attack**: Conduct forensic investigation and restore affected lab datasets.
- **Telemedicine Breach**: Disable compromised user accounts and audit session logs.

4. Communication Plan

- **Primary Communication Channels**: Secure email, encrypted messaging applications.
- **Secondary Communication Channels**: Telephone calls, emergency SMS alerts.
- **Spokesperson**: Chief Information Security Officer (CISO).
- **Escalation Process**: Critical incidents are immediately reported to executive leadership.
- **Communication Goals**: Ensure rapid and clear dissemination of information.

5. Recovery Strategies

- **EHR System**: Database restoration and enforce multi-factor authentication (MFA).
- **PACS**: Rollback to stable server image and verify encryption keys.
- **CPOE**: Revalidate medical orders and integrity checks.
- **LIMS**: Restore redundant backups and rotate credentials.
- **Telemedicine**: Apply security patches and monitor systems.

6. IT Infrastructure Inventory

Component	Location	Function	Configuration
EHR Server	Data Center	Stores patient records	Windows/Linux, SQL DB
PACS Server	Radiology Dept	Manages medical images	DICOM-compliant
CPOE System	Hospital IT	Processes physician orders	Web-based
LIMS	Lab Facility	Manages laboratory data	Cloud-based
Telemedicine App	Remote Hosting	Virtual consultations	WebRTC, AES Encryption

7. IT and Data Backup Plan

- **Backup Model**: Hybrid Cloud (AWS + On-Premises Backup).
- **Data Location**: Redundant storage across cloud facilities.
- **Backup Frequency**: Daily incremental, weekly full.
- **Encryption**: Data encrypted during transmission and storage.

8. Data Backup and Restoration Plan

- **Restoration Priority**: 1. EHR, 2. CPOE, 3. LIMS, 4. PACS, 5. Telemedicine.
- **Cloud Restoration**: Secure VPN and encrypted transfers.
- **On-Prem Restoration**: Tape and disk backups.

9. Resource Inventory

- **Essential Equipment**: Secure servers, backup generators.
- **Supplies**: Network switches, cybersecurity toolkits.
- **Personnel**: IT Security Team, Compliance Officers.

10. Training and Awareness Programs

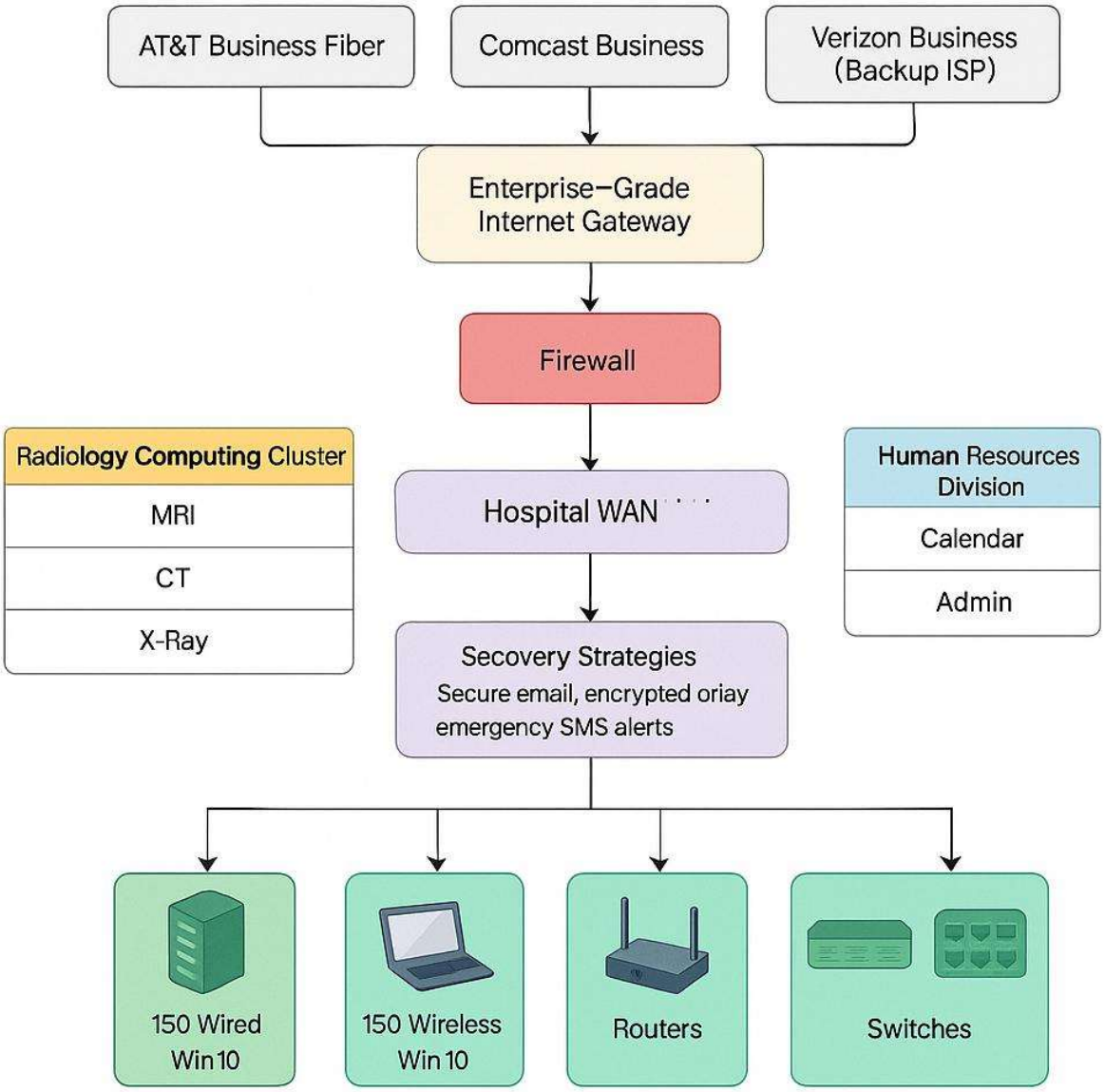
- **Security Training**: Quarterly workshops.
- **Response Drills**: Bi-annual incident response exercises.
- **Documentation**: Clear role-based responsibilities.
-

11. Testing and Maintenance

- **Testing**: Semi-annual disaster recovery drills.
- **Plan Review**: Annual update based on threat landscape.
- **Audit Compliance**: Third-party security audits.

12. Appendices

Appendix A: Updated Network Diagram



Appendix B: MTD, RTO, RPO Table

Department	System	MTD	RTO	RPO
Hospital Administration	EHR System	12hrs	6hrs	1hr
Radiology	PACS	24hrs	12hrs	2hrs
Medical Orders	CPOE System	6hrs	3hrs	30min
Laboratory	LIMS	12hrs	6hrs	2hrs
Remote Consultations	Telemedicine Platform	24hrs	12hrs	4hrs
Imaging	MRI Scanner	48hrs	24hrs	6hrs
Respiratory Support	Ventilators	12hrs	6hrs	1hr
Medication Management	Infusion Pumps	8hrs	4hrs	30min
Patient Monitoring	Monitoring Systems	6hrs	3hrs	1hr
Pharmacy	Medication Dispensing	12hrs	6hrs	2hrs

Appendix C: Incident Response Plan

- **Security Event**: Any observable security-relevant occurrence.
- **Security Incident**: Confirmed breach involving unauthorized access.
- **Team Activation**: CSIRT, IT, Legal, Compliance Teams.
- **Communication Plan**: Secure internal channels and public notifications.
- **Incident Closure**: Root cause addressed, systems secured.

Appendix D: Restoration Procedures

- EHR System: Restore database, enforce MFA.
- PACS: Server snapshot restoration.
- CPOE: Order revalidation.
- LIMS: Cloud backup restoration.
- Telemedicine: Reconnect cloud SaaS, system tests.

13. References

1. Appari, A., & Johnson, M. E. (2010). Information security and privacy in healthcare: Current state of research. *International Journal of Internet and Enterprise Management*, *6*(4), 279–314. https://doi.org/10.1504/IJIEM.2010.035624
2. Kleindorfer, P.R. and Saad, G.H., 2005. Managing disruption risks in supply chains. Production and operations management, 14(1), pp.53-68. https://doi.org/10.1111/j.1937-5956.2005.tb00009.x
3. Comfort, L. K. (2007). Crisis management in hindsight: Cognition, communication, coordination, and control. *Public Administration Review*, *67*(s1), 189–197. https://doi.org/10.1111/j.1540-6210.2007.00827.x
4. Gibb, F., & Buchanan, S. (2006). A framework for business continuity management. *International Journal of Information Management*, *26*(2), 128–141. https://doi.org/10.1016/j.ijinfomgt.2005.11.007
5. Herbane, B. (2010). The evolution of business continuity management: A historical review of practices and drivers. *Business History*, *52*(6), 978–1002. https://doi.org/10.1080/00076791.2010.511185
6. Herbane, B. (2010). Small business research: Time for a crisis-based view. *International Small Business Journal*, *28*(1), 43–64. https://doi.org/10.1177/0266242609350804
7. Ifinedo, P. (2012). Understanding information systems security policy compliance: An integration of the theory of planned behavior and the protection motivation theory. *Computers & Security*, *31*(1), 83–95. https://doi.org/10.1016/j.cose.2011.10.007
8. Kandukuri, B. R., Paturi, V. R., & Rakshit, A. (2009, September). Cloud security issues. In *2009 IEEE International Conference on Services Computing* (pp. 517–520). IEEE. https://doi.org/10.1109/SCC.2009.84
9. Kapucu, N., & Van Wart, M. (2006). The evolving role of the public sector in managing catastrophic disasters: Lessons learned. *Administration & Society*, *38*(3), 279–308. https://doi.org/10.1177/0095399706289593

10. Kwon, J., & Johnson, M. E. (2014). Proactive versus reactive security investments in the healthcare sector. *MIS Quarterly*, *38*(2), 451–471. https://doi.org/10.25300/MISQ/2014/38.2.06
11. Puhakainen, P., & Siponen, M. (2010). Improving employees' compliance through information systems security training: An action research study. *MIS Quarterly*, *34*(4), 757–778. https://doi.org/10.2307/25750704
12. Reynolds, B., & Seeger, M. W. (2005). Crisis and emergency risk communication as an integrative model. *Journal of Health Communication*, *10*(1), 43–55. https://doi.org/10.1080/10810730590904571
13. Rittinghouse, J. W., & Ransome, J. F. (2016). *Cloud computing: Implementation, management, and security*. CRC Press.
14. Sambamurthy, V., Bharadwaj, A., & Grover, V. (2003). Shaping agility through digital options: Reconceptualizing the role of information technology in contemporary firms. *MIS Quarterly*, *27*(2), 237–263. https://doi.org/10.2307/30036530
15. Stephens, K. K., Barrett, A. K., & Mahometa, M. J. (2013). Organizational communication in emergencies: Using multiple channels and sources to combat noise and capture attention. *Human Communication Research*, *39*(2), 230–251. https://doi.org/10.1111/hcre.12006
16. Subashini, S., & Kavitha, V. (2011). A survey on security issues in service delivery models of cloud computing. *Journal of Network and Computer Applications*, *34*(1), 1–11. https://doi.org/10.1016/j.jnca.2010.07.006
17. Tang, C. S. (2006). Perspectives in supply chain risk management. *International Journal of Production Economics*, *103*(2), 451–488. https://doi.org/10.1016/j.ijpe.2005.12.006
18. *Gustin, J.F., 2020. Disaster and recovery planning: A guide for facility managers. River Publishers.* https://doi.org/10.1201/9781003151777
19. Zhang, Q., Cheng, L., & Boutaba, R. (2010). Cloud computing: State-of-the-art and research challenges. *Journal of Internet Services and Applications*, *1*(1), 7–18. https://doi.org/10.1007/s13174-010-0007-6

20. Zawiyah, M. Y., & Abrizah, A. (2012). Disaster recovery planning for digital libraries. *Library Management*, *33*(8/9), 561–574. https://doi.org/10.1108/01435121211279915